

IR Triage Report

Front Matter

ANALYST NAME: Jeevee Balangan
DATE: September 01, 2025
SOURCE: AWS CloudTrail via SIEM
ALERT ID: UR-AWS-20180820-0038
SEVERITY: HIGH
DISPOSITION: True Positive (TP)

Initial Findings

The alert flagged unusual AWS IAM activity involving a high number of API calls from a user account. Investigation confirmed this was part of a larger incident that included leaked IAM credentials, public S3 bucket access, cryptomining on endpoints, persistence through new user accounts, privilege escalation on Linux, and outbound communication with a command-and-control server. Multiple systems and services were affected, and sensitive customer data was confirmed exposed.

Based on this evidence, the incident was assessed as a True Positive with high confidence. The severity was determined to be High due to confirmed compromise, persistence activity, and data exposure, while no indications of a complete environment-wide breach such as ransomware were identified.

Incident Summary

Total time range and duration of incident

Incident activity was observed between 2018-08-20 09:08:01 UTC and 2018-08-20 15:19:35 UTC, spanning a total duration of approximately six hours.

Timeline of key events (UTC)

- **2018-08-20 09:08:01:** Repeated IAM errors begin, including failed CreateAccessKey attempts.
- **2018-08-20 09:16:12:** Attacker attempts to create a new IAM key for user *nullweb_admin*.
- **2018-08-20 09:16:18–09:16:55:** AWS and GitGuardian notify [REDACTED EMAIL] of leaked keys (support case ID [REDACTED CASE ID]).
- **2018-08-20 09:16:22:** First EC2 instance launched using AMI ami-41e0b93b (Ubuntu xenial).
- **2018-08-20 09:27:06:** *DescribeAccountAttributes* called with leaked access key ([REDACTED AWS KEY]), user agent ElasticWolf/5.1.6.

- **2018-08-20 09:36:45–11:24:54:** Root account performs password file reconnaissance and creates new Linux user (*ilovedavidverve*).
- **2018-08-20 09:43–09:55:** Malicious email delivered with attachment *Malware Alert Text.txt*, which decoded to *Frothly-Brewery-Financial-Planning-FY2019-Draft.xlsm* (W97M.Empstage).
- **2018-08-20 09:55:52:** Sysmon confirms execution of *HxTsr.exe* launched from the malicious .xlsm.
- **2018-08-20 09:57:33:** OneDrive logs show upload of *BRUCE BIRTHDAY HAPPY HOUR PICS.lnk* with full UserAgent string.
- **2018-08-20 10:08:17:** Domain admin creates Windows account *svcvnc* with password [REDACTED PASSWORD] and adds to Administrators group.
- **2018-08-20 10:42:49:** Malicious executable *hdoor.exe* written to FYODOR-L.
- **2018-08-20 10:47:06–10:48:57:** PowerShell on FYODOR-L connects to [REDACTED IP] :3333 and downloads */images/logos.png*.
- **2018-08-20 11:08:36–11:13:57:** PowerShell decodes Base64 blobs and writes files *colonel* and *definitelydontinvestigatethisfile.sh* to /tmp.
- **2018-08-20 11:21:40:** New Exchange transport rule created (“SOX”) with BlindCopyTo [REDACTED EMAIL] .
- **2018-08-20 11:43:14–11:44:51:** Expired account *Kevin Lagerfield* logs in successfully from IP [REDACTED IP] .
- **2018-08-20 13:01:46–13:57:54:** S3 bucket *frothlywebcode* made public; files *OPEN_BUCKET_PLEASE_FIX.txt* and *frothly_html_memcached.tar.gz* uploaded.
- **2018-08-20 13:17:33–13:52:00:** Cisco flow logs confirm Monero mining traffic to *coinhive.com* (duration 1667 seconds).
- **2018-08-20 13:37:40:** SEP detects and blocks coin miner on BTUN-L (signature ID 30358).
- **2018-08-20 13:43–14:41:** HTTP logs show repeated hits to */images/2-512.png* (defacement image).
- **2018-08-20 14:03:41–14:59:19:** DNS logs from BSTOLL-L query *coinhive.com*; chrome#5 shows sustained 100% CPU usage.
- **2018-08-20 14:47:12:** Account [REDACTED EMAIL] disabled by [REDACTED EMAIL]
- **2018-08-20 15:15:00:** Email sent to [REDACTED EMAIL] by [REDACTED EMAIL] references external Pastebin; review confirms 8 customer emails exposed.
- **2018-08-20 15:19:35:** Email received by [REDACTED EMAIL] with attachment *1534778082419.png* (base64 inline PNG).

Scope

This incident impacted multiple systems across both Windows and Linux platforms, affecting cloud services, endpoints, and user accounts.

- **Compromised IAM user:** *web_admin* and leaked access key ([REDACTED AWS KEY]).
- **Affected hosts:** FYODOR-L (Windows DA endpoint), ABUNGST-L (C2 contact), BSTOLL-L (cryptomining), BTUN-L (Symantec detection), hoth (Linux server).
- **Affected accounts:** [REDACTED EMAIL] (AWS owner), [REDACTED EMAIL] (OneDrive compromise), *svevnc* (attacker-created Windows account), *tomcat7* (attacker-created Linux account).

Impact

- Unauthorized cloud access with attempted IAM key creation and EC2 instance launch.
- Exposure of S3 bucket *frothlywebcode* with files uploaded.
- Installation of malicious binaries (*hdoor.exe*, *HxTsr.exe*) and persistence through new accounts.
- Cryptomining activity on BSTOLL-L, blocked on BTUN-L.
- Web defacement observed with */images/2-512.png*.
- Exfiltration of 8 customer emails confirmed.

MITRE ATT&CK TTPs observed

- T1078: Valid Accounts (use of leaked AWS keys, compromised user accounts).
- T1136: Create Account (Windows *svevnc*, Linux *tomcat7*).
- T1059: Command and Scripting Interpreter (PowerShell Base64 scriptblocks).
- T1105: Ingress Tool Transfer (download of */images/logos.png*).
- T1505.003: Server Software Component: Web Shell (Linux */tmp* scripts).
- T1496: Resource Hijacking (cryptomining on endpoints).
- T1491: Defacement (repeated hits to */images/2-512.png*).
- T1114.003: Email Collection via Transport Rule (SOX BCC rule).

Threat intelligence indicators

- **C2 IP and URIs:** [REDACTED IP] with */admin/get.php, /news.php, /login/process.php*
 - **Malicious file artifacts:**
 - *BRUCE BIRTHDAY HAPPY HOUR PICS.lnk* (OneDrive upload)
 - *1534778082419.png* (SMTP attachment)
 - *hdoor.exe* (Windows executable, uploaded to FYODOR-L)
 - *HxTsr.exe* (macro-executed binary on BGIST-L)
 - **Hashes:** MD5 = 586EF56F4D8963DD546163AC31C865D7 (*hdoor.exe*)
 - **Malware family:** W97M.Empstage (.xls macro), first discovered by Symantec on 11-12-2016
 - **Domains:** *coinhive.com, minergate.com*
 - **Email addresses:** [REDACTED EMAIL] (adversary exfil email)
-

Recommended Actions

IR-related actions for impacted infrastructure

- Isolate and image compromised endpoints (FYODOR-L, BSTOLL-L, ABUNGST-L, BGIST-L) to contain malicious processes and preserve forensic evidence.
- Reset credentials for affected accounts (*web_admin, svcvnc*, Kevin Lagerfield) and review logs to confirm no additional accounts were created or misused.
- Block outbound connections to adversary C2 infrastructure, specifically IP [REDACTED IP] over port 3333.
- Audit and remediate the S3 bucket *frothywebcode*, ensuring public access is revoked and reviewing other buckets for similar misconfigurations.

Prevention-related recommended actions for impacted infrastructure

- Enforce Multi-Factor Authentication (MFA) for all IAM users. Logs confirmed over 2,000 API calls without MFA.
- Rotate and revoke exposed AWS keys ([REDACTED AWS KEY]) and review IAM permissions for signs of overprovisioning.

- Restrict PowerShell usage on endpoints or enable Constrained Language Mode to reduce abuse opportunities.
- Apply patches and updates across Linux and Windows hosts to mitigate privilege escalation exploits observed in the environment.

Prevention-related recommended actions for internal policies

- Update policy to prevent unauthorized local account creation. Ensure administrative users understand that accounts like *svcvnc* and *tomcat7* must not be created outside of approved processes.
- Expand user awareness training to highlight phishing emails, macro-enabled documents, and malicious file types (.lnk).
- Strengthen policies for credential handling, including guidelines to prevent accidental exposure of AWS keys to public repositories.

Detection-related recommended actions for improved SOC flows

- Enhance PowerShell detection rules by flagging script blocks containing Base64 (FromBase64String) to improve C2 detection.
- Correlate failed login attempts with subsequent successful logins from the same IP (example: Kevin Lagerfield's account accessed from [REDACTED IP]) to better catch password spray scenarios.
- Expand DNS monitoring for known cryptomining destinations (Coinhive, Minergate) and tune alerts for CPU usage spikes correlated with mining domains.
- Update SOC playbooks to explicitly cover:
 - Unauthorized S3 ACL modifications
 - Cryptomining detections combining DNS queries and performance logs
 - Phishing delivery of encoded attachments (.png with base64 payloads)

Priority Order of Actions

1. Immediate Containment: Isolate and image compromised endpoints.
2. Access Control: Reset credentials for affected accounts and revoke exposed AWS keys.
3. Block C2 Communication: Block outbound traffic to [REDACTED IP] :3333.
4. Cloud Security Hardening: Audit S3 bucket permissions and enforce MFA on all IAM users.

5. Endpoint and Network Controls: Apply OS patches, restrict PowerShell, and expand cryptomining DNS monitoring.
 6. Policy and Awareness: Strengthen user training on phishing, credential handling, and policy against unauthorized local accounts.
 7. SOC Process Improvements: Tune detection rules for PowerShell Base64, failed-to-successful logins, and update SOC playbooks.
-

Lessons Learned

Note: The following “Lessons Learned” are mapped to MITRE Mitigations (M-codes), which represent defensive actions. These are distinct from the MITRE Techniques (T-codes) listed earlier in the “TTPs Observed” section, which describe adversary behavior during the incident.

- **Credential management is critical:** AWS keys were exposed and reused by the adversary. Continuous monitoring for credential leaks and enforcing MFA are required to reduce this risk.
 - *Mapped to MITRE M1032: Multi-Factor Authentication*
 - *Mapped to MITRE M1056: Pre-compromise Security Testing*
- **Cloud configuration must be hardened:** Public S3 bucket access provided attackers with upload opportunities. Default-deny policies and routine audits are essential.
 - *Mapped to MITRE M1013: Application Developer Guidance*
 - *Mapped to MITRE M1041: Encrypt Sensitive Information*
- **Cross-platform visibility matters:** The incident impacted both Windows and Linux systems, showing the need for unified monitoring across environments.
 - *Mapped to MITRE M1047: Audit*
 - *Mapped to MITRE M1049: Antivirus/Antimalware*
- **Multi-vector detection is essential:** Adversaries combined cloud misuse, endpoint persistence, cryptomining, and email exfiltration. SOC processes must correlate across these domains.
 - *Mapped to MITRE M1039: Network Intrusion Prevention*
 - *Mapped to MITRE M1042: Disable or Remove Feature or Program*

- **User awareness remains a weak point:** Phishing attachments (.xlsm, .lnk) and malicious rules highlight the need for stronger training and technical safeguards.
 - *Mapped to MITRE M1017: User Training*
 - *Mapped to MITRE M1018: User Account Management*

This report concludes the triage investigation of alert UR-AWS-20180820-0038. The findings and recommendations provided should guide immediate containment, longer-term prevention, and SOC process improvements.